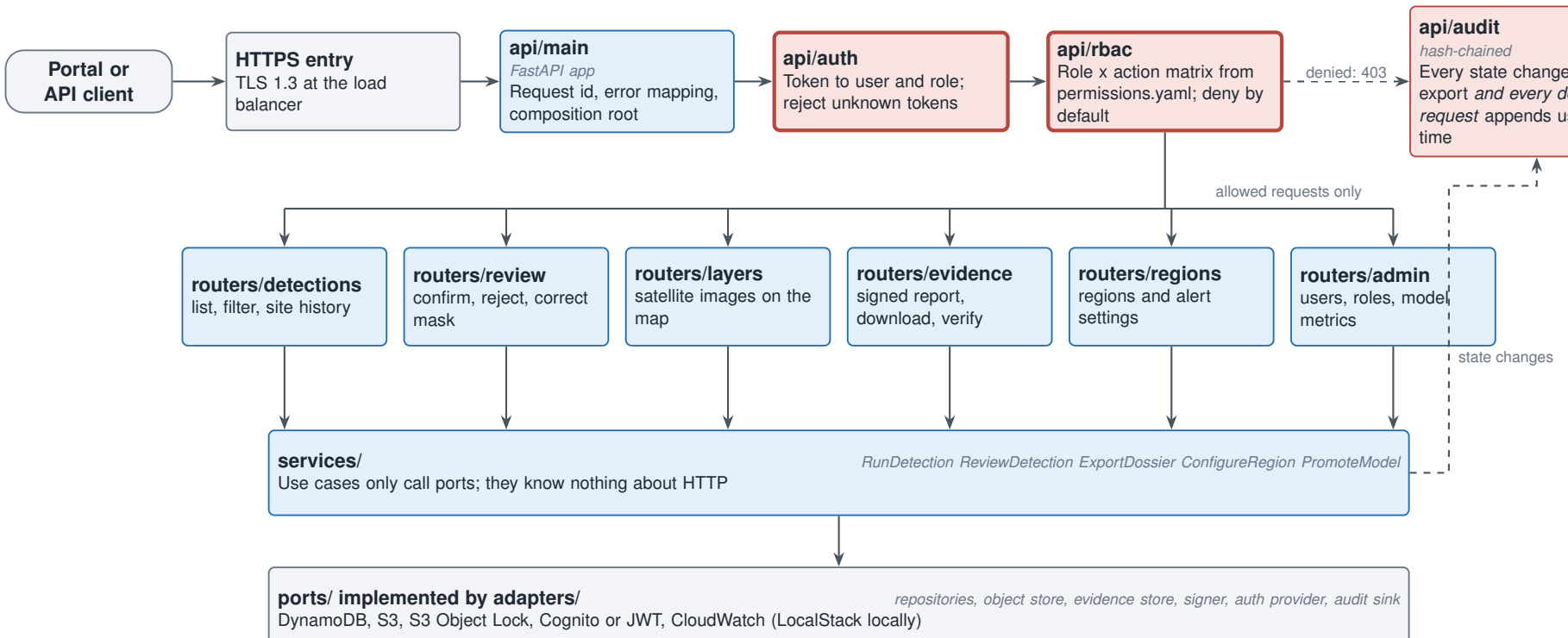
Authorise first, then act: deny by default, audit everything that changes state

Level 02 - API service. Mirrors the service layer of report Figure 5.2.3; FR5 and NFR3.



Test required by the report: a permission matrix covering every role and action; every unauthorised request must be rejected by the backend, and every review, status change and export must create an audit record. The portal never decides access; it only hides what the API would refuse.